Buscador de subvenciones FADE — Acceso de socios mediante enlace firmado

Especificación técnica para la web fade.es · v1.0

1. Objetivo

El nuevo **Buscador de subvenciones** sustituye al dashboard de Power BI de `https://fade.es/zona-privada/buscador-de-subvenciones/`. Está alojado en un servidor propio de FADE, independiente de la web, y se publicará en:

`https://financiacion.fade.es`

Solo deben acceder **socios con sesión iniciada en fade.es**. Como la herramienta está en otro servidor, la protección de la zona privada no le alcanza. Por eso la web de fade.es le "presenta" al socio mediante un **token firmado de corta duración** (JWT).

2. Flujo

1. El socio, con sesión iniciada, abre `https://fade.es/zona-privada/buscador-de-subvenciones/` (desde el menú, como ahora).
2. Esa página **no muestra contenido**: genera un token y responde con una **redirección HTTP 302** a:

   `https://financiacion.fade.es/acceso?token=<JWT>`
3. El Buscador valida el token y abre su propia sesión para el socio, válida durante unas horas.
4. Si el token falta, es inválido o ha caducado, el Buscador redirige a `https://fade.es/login/`.

Si un usuario sin sesión abre la página de fade.es, el comportamiento actual (404 o login) se mantiene. **Nunca se debe generar un token para un usuario que no sea socio.**

3. Formato del token

JWT estándar (RFC 7519) firmado con **HS256** (HMAC-SHA256).

Cabecera:

```
{ "alg": "HS256", "typ": "JWT" }
```

Contenido (claims):

Campo	Obligatorio	Valor
`iss`	Sí	`"fade.es"` (fijo)
`aud`	Sí	`"financiacion.fade.es"` (fijo)
`sub`	Sí	Identificador **estable** del socio, como texto (por ejemplo, el ID de usuario o el número de socio). No debe cambiar entre accesos.
`iat`	Sí	Momento de emisión (segundos Unix)
`exp`	Sí	Caducidad: `iat + 120` (2 minutos)
`jti`	Sí	Valor aleatorio único por token (32 caracteres hex). El Buscador rechaza un token ya usado.

No hace falta incluir más datos personales (nombre, email, etc.).

Ejemplo de contenido:

```
{
  "iss": "fade.es",
  "aud": "financiacion.fade.es",
  "sub": "1234",
  "iat": 1761000000,
  "exp": 1761000120,
  "jti": "9f1c2e7a4b5d6c8e0f1a2b3c4d5e6f70"
}
```

4. Clave secreta

- Es una clave aleatoria de **al menos 32 bytes** que generamos nosotros y os enviamos **por un canal seguro**, nunca por email. Se hará cuando vayáis a implementarlo.
- En la web debe guardarse **fuera del código versionado y de la base de datos**. En WordPress, como constante en `wp-config.php`:

  ```
  define('FADE_FINANCIACION_SECRET', 'clave-que-os-enviaremos');
  ```

- Si la clave se viera comprometida, se cambia en ambos lados y los tokens antiguos dejan de valer al instante.

5. Ejemplo de implementación (PHP / WordPress)

No requiere librerías externas. Puede ir en un plugin propio o en el `functions.php` del tema hijo.

```php
<?php
/**
 * Acceso al Buscador de subvenciones (financiacion.fade.es) mediante
JWT HS256.
 */

function fade_financiacion_b64url($data) {
    return rtrim(strtr(base64_encode($data), '+/', '-_'), '=');
}

function fade_financiacion_token($socio_id) {
    $ahora = time();
    $cabecera  = ['alg' => 'HS256', 'typ' => 'JWT'];
    $contenido = [
        'iss' => 'fade.es',
        'aud' => 'financiacion.fade.es',
        'sub' => (string) $socio_id,
        'iat' => $ahora,
        'exp' => $ahora + 120,
        'jti' => bin2hex(random_bytes(16)),
    ];
    $h = fade_financiacion_b64url(json_encode($cabecera));
    $c = fade_financiacion_b64url(json_encode($contenido));
    $firma = hash_hmac('sha256', "$h.$c", FADE_FINANCIACION_SECRET,
true);
    return "$h.$c." . fade_financiacion_b64url($firma);
}

add_action('template_redirect', function () {
    if (!is_page('buscador-de-subvenciones')) {
        return;
    }
    if (!is_user_logged_in()) {
        return; // Se mantiene el comportamiento actual de la zona
privada
    }

    $usuario = wp_get_current_user();

    // ADAPTAR: comprobar que el usuario es socio según vuestro
sistema
    // (rol, plugin de membresía, etc.). Si no lo es, no generar
token.
    // if (!es_socio($usuario)) { return; }
```

```
    // ADAPTAR: usar el identificador estable del socio
    // (ID de usuario de WordPress o número de socio).
    $socio_id = $usuario->ID;

    nocache_headers();
    wp_redirect(
        'https://financiacion.fade.es/acceso?token=' .
rawurlencode(fade_financiacion_token($socio_id)),
        302
    );
    exit;
}, 20);
```

Notas:

- La página debe **excluirse de cualquier caché** (plugin de caché, CDN), porque cada visita genera un token distinto. `nocache_headers()` ayuda, pero conviene excluirla también en la configuración de caché.
- El reloj del servidor de la web debe estar sincronizado (NTP). El Buscador tolera hasta 30 segundos de desfase.
- Si la web no es WordPress, cualquier librería JWT estándar sirve (por ejemplo, `firebase/php-jwt`) con los mismos campos.

6. Pruebas antes del lanzamiento

Lo haremos de forma conjunta:

1. Un socio con sesión pulsa “Buscador de subvenciones” → entra en el Buscador sin volver a identificarse.
2. Un usuario sin sesión abre la página de fade.es → comportamiento actual (404 o login).
3. Abrir `https://financiacion.fade.es` directamente, sin token → redirige a `fade.es/login`.
4. Reutilizar un enlace con token ya usado, o pasados 2 minutos → rechazado.

7. Contacto

Para cualquier duda sobre esta especificación, contactad con FADE (área de financiación).